

Charte de Conformite RGPD

Projet Alumni CRM - Version complete et fidele au code source

1. Contexte Juridique

Le principal defi juridique d'un annuaire d'anciens reside dans le respect strict des donnees personnelles. Le CRM integre une tracabilite native et inalterable via la table CONSENTEMENT_RGPD, conforme au Reglement (UE) 2016/679 (RGPD) et a la loi Informatique et Libertes. Le chiffrement specifique des donnees de consentement n'est pas implemente au niveau applicatif (protection confiee aux mecanismes de l'infrastructure), et aucune fonctionnalite de notification de violation de donnees n'existe a ce jour.

2. Les 4 Types de Consentement Implements

Le systeme differencie quatre categories precises de consentement, chacune etant gerée independamment via des toggles dedies dans l'interface alumni (AlumniConsent.jsx).

Type (Backend)	Cle Frontend	Description
prise_de_contact	contact_allowed	Autoriser l'ecole et les partenaires a contacter l'alumni pour des opportunités professionnelles, des evenements ou des enquetes.
partage_donnees	data_sharing	Autoriser le partage anonymise de donnees statistiques (secteur, poste) avec les entreprises partenaires.
enquetes	survey_participation	Accepter de recevoir et de repondre aux enquetes alumni sur l'evolution professionnelle et la satisfaction.
newsletter	newsletter	Recevoir la newsletter alumni avec les actualites, evenements et offres d'emploi.

3. Mecanisme de Gestion du Consentement

3.1 Collecte du consentement

- Canal principal : formulaire d'inscription Web (AlumniRegistration.jsx).
- Canal secondaire prevu : questionnaire annuel (AlumniSurvey.jsx) ; a ce jour seul le canal 'web' est reellement emis par le frontend.
- Chaque consentement est enregistre avec : type_consentement, statut (actif/refuse), date_consentement, canal, id_etudiant.
- L'endpoint POST /consentements/ cree ou met a jour le consentement pour chaque type.
- L'interface de consentement informe l'alumni de la duree de conservation des donnees (suppression 6 mois apres anonymisation) et affiche le contact du DPO (contact@ionis-stm.com).

3.2 Modification et retrait

- L'alumni peut modifier ses preferences a tout moment via l'interface de consentement.
- Le retrait du consentement est modelise par un nouveau vote 'refuse' avec la date courante.
- L'interface affiche la date de derniere mise a jour du consentement.
- Une suppression physique d'un enregistrement reste possible via DELETE /consentements/{id_consentement} (proprietaire ou admin) ; le retrait usuel conserve l'historique complet des votes.

3.3 Traçabilité

- Enregistrement de la date exacte du recueil (date_consentement).
- Identification formelle du canal de collecte (formulaire inscription, questionnaire).
- Historique complet des votes de consentement dans la base de données.

3.4 Consommation des consentements (relations fonctionnelles)

Chaque consentement est réellement consommé par une fonctionnalité du système : un refus (statut 'refuse') désactive l'usage correspondant. Un alumni sans vote sur un type reste éligible ('inconnu' tolère), par cohérence avec l'émission du consentement. Le vote le plus récent est déterminé par une sous-requête corrélée identique partout (ORDER BY date_consentement DESC, id_consentement DESC LIMIT 1).

- 'newsletter' : recevoir les newsletters (POST /newsletter/envoyer, ciblage par promotion / secteur / consentis actifs).
- 'enquetes' : accéder au questionnaire actif (GET /questionnaires/actif) et recevoir les relances (POST /admin/questionnaires/notifier). Un refus bloque la restitution du questionnaire (HTTP 403) et masque le lien 'Enquête annuelle' dans la navigation alumni (AlumniLayout.jsx).
- 'prise_de_contact' : recevoir newsletter et relances questionnaire ; un refus exclut l'alumni des deux envois (newsletter.py et questionnaires.py). C'est le seul consentement dont le refus déclenche l'anonymisation du profil via cleanup.py (CONSETEMENT_ARCHIVE_TYPE = 'prise_de_contact').
- 'partage_donnees' : seul ce périmètre (alumni ayant accepté le partage) alimente les indicateurs partenaires GET /admin/indicateurs/partenaires (comptages et moyennes d'insertion anonymisées, aucune donnée personnelle avec le partenaire).

4. Droits RGPD Implémentés dans l'Interface

L'interface alumni affiche et implémente les droits suivants :

- Droit d'accès à vos données personnelles : page de profil en lecture seule, suivi des demandes via GET /rgpd/demandes/moi et export json/Excel/CSV auto-service via GET /rgpd/export.
- Droit de rectification et de mise à jour (AlumniProfile.jsx).
- Droit à l'effacement (droit à l'oubli) : mentionné dans l'interface, implémente via un workflow de demandes auto-service (POST /rgpd/demandes) traité par anonymisation puis purge différée.
- Droit de retrait du consentement à tout moment (AlumniConsent.jsx avec toggles).

5. Modèle de Données CONTEMENT_RGPD

Champ	Type	Contraintes
id_etudiant	Entier (FK)	NOT NULL, référence vers ETUDIANT.id_etudiant.
type_consentement	Enum / Chaîne	Valeurs : 'prise_de_contact', 'partage_donnees', 'enquetes', 'newsletter'.
date_consentement	Date	NOT NULL, date du jour au moment de l'opération.
statut	Chaîne	Deux valeurs implémentées : 'actif' (consentement accordé), 'refuse' (refuse ou retire). Aucun statut 'revoque' distinct n'existe : le retrait passe par un nouveau vote 'refuse' horodaté.

canal	Chaîne	Origine : 'web' (formulaire inscription), 'questionnaire' (enquête annuelle, valeur acceptée par l'API mais non encore émise par le frontend à ce jour).
-------	--------	--

6. Workflow des Demandes RGPD (Effacement et Portabilité)

Au-delà du consentement, le CRM met en œuvre un workflow complet de traitement des droits d'accès, d'effacement et de portabilité, basé sur la table DEMANDE_RGPD :

- Depot auto-service : POST /rgpd/demandes (types 'export' ou 'suppression') ; suivi et annulation par l' alumni via GET /rgpd/demandes/moi et DELETE /rgpd/demandes/{id}.
- Cycle de statuts : envoyée -> en_traitement -> traitée/rejetée (contrainte SQL, migration 009), avec verrou anti-traitement parallèle (prise_en_charge_par, date_prise_en_charge).
- Traitement d'une demande de suppression = anonymisation irréversible (email remplacé par ANONYMISE_<id>@anonymise.io, données personnelles effacées), puis purge physique différée après PURGE_DELAY_MONTHS mois (défaut 6) via purge.py (--dry-run disponible) ou POST /admin/demandes-rgpd/purge-anonymises.
- Portabilité : export json/Excel/CSV auto-service via GET /rgpd/export ; exports admin unitaires et en masse.
- Opérations tracées dans AUDIT_LOG (acteur, action, détails).